



QuXAT Healthcare Data Safety - Self Assessment Checklist

This checklist is designed to help organizations assess their data safety posture against ISO 27001:2022 controls and Ransomware readiness.

Scoring Guide (Self-Assessment)

Use the following criteria to score your implementation status:

Score	ISO 27001 Criteria	Ransomware Readiness Criteria
0	Not Implemented - Control is missing or ad-hoc.	No - Practice is not in place.
50	Partially Implemented - Control exists but is not documented or consistently applied.	Partial - Practice is in place but not fully effective or consistent.
100	Implemented - Control is fully documented, implemented, and effective.	Yes - Practice is fully established and effective.

ISO 27001:2022 Controls Assessment

Control	Clause	Description	Score (0/50/100)
Access Control Policy	ISO/IEC 27001:2022 Annex A 5.15	Formal documented access control policy covering all healthcare information systems and electronic health records.	
User Access Provisioning	ISO/IEC 27001:2022 Annex A 5.18	Controlled process for granting, modifying and revoking user access rights based on job role and approval.	
Backup Schedule and Testing	ISO/IEC 27001:2022 Annex A 8.13	Defined backup schedule and regular restoration tests for critical clinical and administrative data.	
Offsite Backup Storage	ISO/IEC 27001:2022 Annex A 8.13	Secure storage of backup copies in an offsite location or logically isolated cloud environment.	
Database Encryption	ISO/IEC 27001:2022 Annex A 8.24	Use of strong cryptographic controls to protect databases holding patient and clinical information.	
Endpoint Disk Encryption	ISO/IEC 27001:2022 Annex A 8.24	Full disk or volume encryption for laptops, desktops and mobile devices used for healthcare operations.	
Incident Response Plan	ISO/IEC 27001:2022 Annex A 5.26	Documented incident response procedures for detecting, responding to and learning from security incidents.	
Incident Logging and Monitoring	ISO/IEC 27001:2022 Annex A 8.15	Centralised logging and monitoring of security events on critical healthcare applications and infrastructure.	
Vendor Risk Assessment	ISO/IEC 27001:2022 Annex A 5.19	Assessment of information security risks related to third party and vendor services handling health data.	
Vendor Data Processing Agreements	ISO/IEC 27001:2022 Annex A 5.20	Documented agreements with vendors defining security, privacy and data processing obligations.	
Asset Inventory of Medical Devices	ISO/IEC 27001:2022 Annex A 5.9	Up to date inventory of network connected and standalone medical devices that process health information.	

Asset Inventory of Servers and Workstations	ISO/IEC 27001:2022 Annex A 5.9	Comprehensive inventory of servers, workstations and virtual machines supporting healthcare operations.	
Business Continuity Plan	ISO/IEC 27001:2022 Annex A 5.30	Business continuity plan covering continuity of clinical and administrative services during disruptions.	
Disaster Recovery Testing	ISO/IEC 27001:2022 Annex A 5.30	Regular testing and review of disaster recovery capabilities for key healthcare systems.	
Secure Configuration Baselines	ISO/IEC 27001:2022 Annex A 8.9	Defined secure configuration standards and baseline hardening for systems, applications and networks.	

Ransomware Readiness Checklist

Question	Clause	Description	Score (0/50/100)
Are backup copies stored offline or logically isolated from the main network?	ISO/IEC 27001:2022 Annex A 8.13	Assesses whether backups are protected from ransomware by being offline, immutable or stored in a segregated environment.	
Is multi factor authentication enabled for remote access and privileged user accounts?	ISO/IEC 27001:2022 Annex A 5.17	Checks whether more than one authentication factor is required for high risk and administrative access.	
Is the electronic health record system and stored patient data encrypted at rest?	ISO/IEC 27001:2022 Annex A 8.24	Evaluates whether cryptographic controls protect sensitive health records from unauthorised disclosure.	
Is anti malware protection deployed and regularly updated on all relevant systems?	ISO/IEC 27001:2022 Annex A 8.7	Covers deployment and maintenance of anti malware tools on servers, workstations and endpoints.	
Is the network segmented to separate critical healthcare systems from general user networks?	ISO/IEC 27001:2022 Annex A 8.20	Looks at use of network segmentation and zoning to limit lateral movement of ransomware.	
Is there an automated or regularly executed process for applying security patches?	ISO/IEC 27001:2022 Annex A 8.8	Checks whether operating systems and applications receive timely security updates.	
Is regular phishing and cyber security awareness training conducted for all staff?	ISO/IEC 27001:2022 Annex A 6.3	Assesses whether staff receive ongoing training to recognise and report phishing attempts.	
Is administrative access restricted to authorised personnel following least privilege principles?	ISO/IEC 27001:2022 Annex A 5.18	Evaluates whether privileged accounts are tightly controlled, monitored and limited.	

QuXAT Data Security - Advisory Team

Whatsapp: +91 6301237212

Email ID: quxat.team@gmail.com

Website: www.quxat.com